

Test Plan 11 - Product Fraud and Account-Takeover Controls

Project	fraud
Specs	tests/fraud/account-takeover.spec.ts , tests/fraud/anti-fraud-controls.spec.ts
Target	Product app origin and auth/RPC backend selected by QA_TARGET_ENV
Cases	14 (8 ATO + 6 anti-fraud)
Execution	Browserless APIRequestContext ; active locally and in the dev CI matrix
Safety	Fabricated identities, verify-only auth probes, no OTP sends

Scope

Authorized, non-destructive checks for account takeover, forged credentials, transport and browser hardening, CORS, injection handling, secret leakage, and OTP brute-force behavior. The suite complements security : security targets the Organuz Supabase backend, while fraud targets the calculator product and its auth/RPC gateway.

Gating

- App-origin checks always run against the selected environment.
- Auth-backend checks skip when the gateway is unreachable or serves an HTML block/challenge page.
- ATO-08 is prod-only and requires FRAUD_OTP_VERIFY_CALL .
- The OTP brute-force uniformity probe also requires FRAUD_OTP_VERIFY_CALL .
- HSTS and clickjacking findings are strict on prod and annotated as known gaps on the gated dev environment.

Case groups

GROUP	CASES	COVERAGE
Account takeover	8	HTTPS/redirect, HSTS, clickjacking, forged and empty tokens, injection/error hygiene, dev OTP rejection on prod
Anti-fraud	6	Origin/backend CORS, secret and cookie hygiene, reflected XSS, OTP brute-force uniformity

Configuration

- `FRAUD_AUTH_BACKEND` - optional auth-backend origin override.
- `FRAUD_APP_TOKEN` - optional public app-token override.
- `FRAUD_OTP_VERIFY_CALL` - names the live verify method for gated OTP probes.

Run

```
npx playwright test --project=fraud
QA_TARGET_ENV=prod npx playwright test --project=fraud
```